

Cyber Security Risk Assessment & Strategic Planning

E-Governance Digital Services Environment

Candidate: Yuva Intern – NSDC | Domain: Information Security & E-Governance

1. Executive Summary

This report presents a comprehensive cyber security risk assessment and strategic mitigation plan for an e-governance digital service environment. E-governance platforms manage sensitive citizen data — identity records, financial details, and health information — while remaining publicly accessible, which makes them high-value targets for cyber attackers.

The assessment identifies ten key risk areas spanning application security, network security, identity and access management, and third-party/supply chain exposure. Three risks — SQL injection vulnerabilities, phishing/credential theft, and unpatched legacy systems — are rated **Critical** and require immediate remediation within 30 days. The report concludes with a prioritized risk matrix and a strategic control plan mapped to ownership and timelines, enabling the organization to systematically reduce its cyber risk exposure.

2. Methodology

The risk assessment was conducted using a structured, industry-aligned approach combining publicly available cyber security frameworks and best practices for public sector digital services:

- **Reference Frameworks:** NIST Cybersecurity Framework (Identify, Protect, Detect, Respond, Recover), ISO/IEC 27001 Information Security Management guidelines, and OWASP Top 10 for web application risks.
- **Risk Identification:** Systematic review of common e-governance attack surfaces — citizen web/mobile portals, inter-department APIs, databases holding Personally Identifiable Information (PII), and administrative systems.
- **Risk Analysis:** Each identified risk was evaluated on Likelihood (probability of occurrence) and Impact (severity of consequence to citizens and government operations), rated as Low, Medium, or High.
- **Risk Prioritization:** Likelihood and Impact were combined into an overall Risk Level (Critical, High, Medium, Low) to rank issues by urgency.
- **Mitigation Planning:** Controls were mapped to each risk, following the principle of matching control strength to risk severity, with realistic ownership and implementation timelines.

3. Risk Identification

The following categories of threats and vulnerabilities were identified as most relevant to public digital services:

3.1 Application-Layer Threats

- Injection attacks (SQL injection, cross-site scripting) due to insufficient input validation on citizen-facing forms.
- Insecure or poorly authenticated APIs used to exchange data between government departments.

3.2 Identity & Access Risks

- Phishing and credential theft targeting both citizens and government staff.
- Weak authentication practices and absence of multi-factor authentication (MFA) on administrative panels.
- Insider threats arising from excessive privileges or inadequate access reviews.

3.3 Infrastructure & Availability Risks

- Unpatched, end-of-life, or legacy systems still in production use.
- Ransomware attacks capable of encrypting critical citizen data and disrupting services.

- Distributed Denial-of-Service (DDoS) attacks against public-facing portals during high-traffic periods (e.g., tax filing deadlines).

3.4 Data & Third-Party Risks

- Breach or leakage of citizen Personally Identifiable Information (PII), including identity, financial, and health data.
- Supply chain and third-party vendor vulnerabilities introduced through outsourced development or hosting.

4. Risk Matrix & Prioritization

Each risk was scored on Likelihood and Impact and assigned a combined Risk Level to determine remediation priority (1 = most urgent):

Risk ID	Risk / Threat	Likelihood	Impact	Risk Level	Priority
R-01	SQL Injection / Input validation flaws on citizen service portals	High	High	Critical	1
R-02	Phishing & credential theft targeting citizens and staff	High	High	Critical	2
R-03	Unpatched legacy systems and outdated software	High	High	Critical	3
R-04	Insecure APIs used for inter-department data exchange	Medium	High	High	4
R-05	Ransomware attacks on government data servers	Medium	High	High	5
R-06	Data breach of citizen PII (identity, financial, health records)	Medium	High	High	6
R-07	Insider threats / privilege misuse by employees	Medium	Medium	Medium	7
R-08	DDoS attacks on public-facing e-governance portals	Medium	Medium	Medium	8
R-09	Weak authentication / lack of MFA on admin panels	Medium	Medium	Medium	9
R-10	Third-party / vendor supply chain vulnerabilities	Low	Medium	Low	10

Legend:
Critical (Red) — immediate action required
 |
 High (Amber) — action required in near term
 |
 Medium / Low — monitor and remediate on standard schedule.

5. Strategic Mitigation Plan

The following controls are recommended for each identified risk, aligned to ownership and implementation timeline:

Risk ID	Recommended Control / Mitigation Strategy	Owner	Timeline
R-01	Implement parameterized queries/prepared statements, input validation, and a Web Application Firewall (WAF) across all citizen portals.	Application Security Team	0–30 days
R-02	Deploy email/SMS phishing filters, run periodic staff awareness training, and enable multi-factor authentication (MFA) for citizen and staff logins.	IT Security & HR	0–30 days
R-03	Establish a formal patch management policy; inventory and upgrade end-of-life systems on a defined schedule.	Infrastructure Team	0–60 days
R-04	Enforce API authentication (OAuth2/API keys), rate limiting, and encryption (TLS) for all inter-department data exchange.	Integration / DevOps Team	30–60 days

RISK ID	RECOMMENDED CONTROL / MITIGATION STRATEGY	OWNER	TIMELINE
R-05	Maintain offline/immutable backups, deploy endpoint detection & response (EDR), and create a ransomware incident response playbook.	IT Security Team	30–60 days
R-06	Encrypt PII at rest and in transit, apply data masking/anonymization, and enforce role-based access control (RBAC).	Data Governance Team	30–90 days
R-07	Apply least-privilege access, enable audit logging of privileged actions, and conduct periodic access reviews.	IT Security Team	30–90 days
R-08	Deploy DDoS protection/CDN services and configure auto-scaling and traffic monitoring on public portals.	Infrastructure Team	30–60 days
R-09	Mandate MFA and strong password policies for all administrative and privileged accounts.	IT Security Team	0–30 days
R-10	Conduct vendor security assessments, include security clauses in contracts, and monitor third-party access.	Procurement & Security Team	60–90 days

6. Key Steps Undertaken

- Researched current cyber security risk management frameworks relevant to e-governance (NIST CSF, ISO 27001, OWASP Top 10).
- Identified possible threats and vulnerabilities associated with public digital services.
- Built a risk matrix scoring each risk by likelihood, impact, and overall risk level.
- Developed a prioritized, owner-mapped strategic mitigation plan for identified risks.
- Compiled all findings into this structured report.

7. Conclusion

Securing e-governance platforms requires a layered defense strategy that addresses application vulnerabilities, strengthens identity and access controls, modernizes infrastructure, and safeguards citizen data. By prioritizing the Critical and High risks identified in this assessment — input validation flaws, phishing exposure, legacy systems, insecure APIs, ransomware readiness, and PII protection — the organization can significantly reduce its overall attack surface. Continuous monitoring, periodic re-assessment, and staff awareness training should accompany the technical controls outlined above to maintain a resilient security posture over time.